

Security incident report

Section 1: Identify the network protocol involved in the incident

the Hypertext transfer protocol (HTTP).

Since the issue was with accessing the web server for yummyrecipesforme.com, we know that requests to web servers for web pages involve http traffic. Also, when we ran tcpdump and accessed the yummyrecipesforme.com website the corresponding tcpdump log file showed the usage of the http protocol when contacting the website . The malicious file is observed being transported to the users' computers using the HTTP protocol at the application layer.

Section 2: Document the incident

The analyst ran tcpdump while accessing the website and observed the browser downloading a file and then being redirected to a different website. The analyst examined the traffic to the website and the downloaded file. The analyst discovered that an attacker had manipulated the websites and the downloaded file. The analyst discovered that an attacker had manipulated the website to add code that prompted the users to download a malicious file disguised as a browser update. Since the website owner stated that they had been locked out of their administrator account, the team believes the attacker used a brute force attack to access the account and change the admin password. The execution of the malicious file compromised the end users' computers.

Section 3: Recommend one remediation for brute force attacks

One security measure the team plans to implement to protect against brute force attacks is to disallow previous passwords from being used. Since the vulnerability that led to this attack was the attacker's ability to use a default password to log in, it's important that we prevent any old passwords such as default passwords from being used to reset the password. Another supportive measure is to require more frequent password updates, so in case any unauthorized person becomes aware of the password, they are less likely to be able to use that password if the password is updated sooner than later. Finally, another helpful solution is to implement two-factor authentication (2FA). 2FA requires authentication via a password and also by confirming a one-time passcode (OTP) sent to either their email or phone. Once the user confirms their identity through their login credentials and the OTP, they will gain access to the system. Any malicious actor that attempts a brute force attack will not likely gain access to the system because it requires additional authentication.